MIZAN: A Quantitative Framework for Non-Invasive OSINT Compliance

Abstract

Modern Open Source Intelligence (OSINT) suffers from two critical and well-documented failures. First, the **Observer Effect**: the act of investigating a digital identity leaves traces that can alert the target, compromise the investigation, or contaminate the digital environment. Second, **Adjacent Data Leakage**: non-targets such as family members, colleagues, and associates are inadvertently exposed when investigations lack formal ethical boundaries.

Despite growing awareness of these issues, the OSINT community continues to rely on qualitative, subjective "best practices" that offer no measurable criteria for ethical compliance. This paper proposes the **MIZAN Protocol**, a formal framework designed to quantify and minimize the "Digital Blast Radius" of any OSINT investigation through a zero-touch evidence synthesis model and a mathematical heuristic for ethical risk assessment.

1. Introduction: The Crisis of Ethical Persistence

As digital footprints become more persistent and interconnected, the line between "publicly available data" and "private life" has effectively dissolved. A person's social media activity, location metadata, online purchases, and professional connections form an intricate web that, once accessed, reveals far more than any single data point suggests.

Traditional OSINT ethics rely on subjective judgment: "Is this data public? Is my intent justified?" These questions, while important, lack quantitative rigor and cannot be audited, reproduced, or standardized across teams.

The MIZAN Protocol seeks to move from subjective evaluation to **Ethical Attestation**, where every data point in an investigation must carry a provenance tag and a computed Impact Score before it is admitted into the evidence corpus.

1.1 The Observer Effect in OSINT: A Real and Documented Problem

The Observer Effect is not theoretical. It is a measurable, real-world phenomenon that compromises OSINT investigations daily:

- **Platform Notification Systems:** LinkedIn displays "who viewed your profile." Instagram shows message read receipts. Facebook logs access locations. Simply viewing a target's profile can trigger an alert, causing the target to change behavior, destroy evidence, or increase security measures.
- **Automated Behavioral Detection:** Major social platforms deploy machine learning systems that monitor user behavior patterns. Predictable scrolling, excessive profile viewing, rapid friend-request patterns, and unusual access times are flagged automatically. These systems can lock investigator accounts, alert platform administrators, or indirectly signal to the target that abnormal activity has occurred.
- **Investigator Fingerprinting:** Even when using VPNs, investigators leave identifiable traces through WebRTC leaks, browser fingerprints, cookie trails, and user-agent strings. A sophisticated target or platform can correlate these traces to identify repeated access from the same source, effectively unmasking the investigator.
- **Behavioral Contamination:** When a target becomes aware of surveillance (even subconsciously through unusual platform notifications), their digital behavior changes. Posts are deleted, accounts are locked, and communication shifts to encrypted or offline channels. The investigation has, in effect, destroyed the evidence it sought to collect.

1.2 Adjacent Data Leakage: The Invisible Collateral Damage

Perhaps the most ethically dangerous aspect of unstructured OSINT is the exposure of non-targets. When an investigator maps a target's social network, they inevitably access data belonging to people who have no connection to the investigation:

- **Family Exposure:** A target's spouse, children, or parents may have their social profiles, photographs, location data, and personal details inadvertently captured and stored in an investigation file.
- **Professional Contamination:** Colleagues, business partners, and casual professional connections may be flagged as "persons of interest" simply because of their digital proximity to the target.
- **Misidentification Risk:** In public OSINT investigations, misidentification has led to innocent individuals being doxxed, harassed, and threatened. This is not a theoretical risk; it is a documented pattern with real-world consequences.

No existing framework provides a quantitative method for measuring or limiting this collateral exposure. The MIZAN Protocol addresses this gap directly.

2. The Blast Radius Calculus (BRC)

The core contribution of this framework is the **Blast Radius Calculus**, a heuristic for determining the ethical risk of a specific investigation branch before it is executed.

2.1 The Formula

The Ethical Risk Score (ERS) is defined as:

$$ERS = \Phi(S, A, E)$$

Where:

- **S (Sensitivity):** The inherent privacy value of the data being accessed. This ranges from fully public content (e.g., a public tweet) to highly sensitive data (e.g., leaked metadata, geolocation history, private messages obtained through platform vulnerabilities). Sensitivity is scored on a scale of 0.0 to 1.0.
- **A (Adjacency):** The degree of separation between the data subject and the primary target. An A score of 0 indicates the data belongs directly to the target. An A score of 1 indicates a first-degree connection (spouse, direct colleague). Higher values indicate greater separation. The ethical threshold increases proportionally with Adjacency; data about non-targets requires significantly stronger justification.
- **E (Entropy):** The disturbance caused by the collection method in the target's digital environment. Passive methods (cached data retrieval, public archive access) have low Entropy. Active methods (direct profile viewing, sending connection requests, triggering API calls that generate logs) have high Entropy. Entropy is the primary indicator of Observer Effect risk.

2.2 Threshold and Decision Logic

An investigation step is only approved when:

$$ERS < \tau$$

Where τ (tau) is the **Ethical Threshold**, a configurable value that depends on the investigation context (law enforcement, corporate security, journalistic investigation, academic research). Each context has a different tolerance for risk, and the threshold is set accordingly by the investigating organization.

2.3 Practical Application

Before any data collection step, the investigator (or an automated tool implementing the protocol) computes the ERS. If the score exceeds the threshold, the step is blocked and must be either:

1. Replaced with a lower-entropy alternative, or
2. Escalated for formal ethical review and documented justification.

This creates an auditable, reproducible decision trail for every piece of evidence collected.

---

3. Minimal-Interaction Evidence Synthesis (MIES)

The second pillar of the MIZAN Protocol is **MIES**: a methodology for evidence collection that minimizes or eliminates direct interaction with the target's digital environment.

3.1 Core Principles

- **Cache-First Collection:** Always prefer cached or archived versions of content (e.g., Google Cache, Wayback Machine, CDN mirrors) over live access.
- **Proxy Synthesis:** When live access is necessary, route through anonymization layers that eliminate fingerprinting (randomized user-agents, Tor circuits, isolated virtual machines).
- **Temporal Separation:** Avoid accessing multiple related data points within short timeframes, which can trigger behavioral detection algorithms.
- **Zero-Footprint Verification:** Every collection method must be tested against a control environment to verify that it leaves no detectable trace on the target platform.

3.2 OpSec Requirements

- Dedicated investigation environments (isolated VMs, Whonix/Tails OS)
- No-log VPN services with verified audit reports
- Browser fingerprint randomization (Mullvad Browser, custom Firefox profiles)
- Strict identity compartmentalization (no personal account usage during investigation)
- Metadata sanitization of all collected files (ExifTool, MAT2, BleachBit)

---

4. Proof-of-Ethical-Conduct (PoEC)

Every piece of evidence gathered under the MIZAN Protocol must include a **Proof-of-Ethical-Conduct (PoEC)** signature. This creates a complete Chain of Custody for digital evidence.

4.1 PoEC Components

1. **Source Pathway:** The exact URL, API endpoint, or data source from which the evidence was obtained. This must be specific enough to be independently auditable.
2. **Access Method:** The tool, user-agent, network configuration, and timestamps used during collection. This allows forensic verification that the collection method was non-invasive.
3. **ERS Score:** The computed Ethical Risk Score at the time of collection, along with the threshold that was applied.
4. **Informed Consent Logic:** A formal justification for why the data was accessed without subject consent, grounded in the legal and professional context of the investigation.
5. **Data Integrity Hash:** A cryptographic hash of the evidence at the moment of collection, ensuring that the data has not been modified, fabricated, or contaminated by AI hallucination.

---

5. Regional Sensitivity & The High-Connectivity Context

Most existing OSINT ethics frameworks are designed with Western digital cultures in mind — cultures where social networks are relatively diffuse, family structures are nuclear, and privacy norms are individually defined. These assumptions fail catastrophically in high-connectivity cultures where social structures are denser, family networks are vastly larger, and cultural privacy expectations diverge sharply from Western norms.

The MIZAN Protocol was designed with these environments in mind. This section uses Saudi Arabia and the broader GCC region as a primary case study, though the principles apply to any high-connectivity culture.

5.1 The Family Network Density Problem

In Saudi Arabia and much of the Gulf region, extended family networks are orders of magnitude larger and more tightly connected than Western equivalents. A single individual may have 40 to 80 first cousins, all of whom share a family name, many of whom live in the same city, and most of whom are connected across multiple digital platforms.

This creates a fundamental challenge for the Adjacency factor (A): what would be a second or third-degree connection in a Western context is effectively a first-degree connection in a Saudi context. Investigating one family member creates a ripple effect that can expose an entire lineage.

Example scenario: An investigator targets an individual named Abdullah Al-[Family]. A standard OSINT workflow would map Abdullah's social connections. In a Western context, this might reveal 15 to 30 close connections. In a Saudi context, searching the family name alone can return hundreds of profiles sharing that name — exposing uncles, cousins, in-laws, and extended family members who have zero relevance to the investigation but whose data is now in the investigator's collection.

The MIZAN Protocol addresses this by applying a **Family Name Multiplier** to the Adjacency score in high-connectivity contexts. When a data point is associated with a shared family name rather than a direct personal connection, the Adjacency score is elevated automatically.

5.2 Tribal and Family Name Searchability

In many Gulf societies, a family name is not merely an identifier — it carries information about tribal affiliation, geographic origin, and social standing. Searching a family name in an OSINT context is not equivalent to searching "Smith" or "Johnson" in a Western context. It is closer to searching an entire community.

A single family name search on platforms like X (Twitter), Instagram, or LinkedIn can inadvertently surface data on dozens or hundreds of individuals who share the name. This is a form of Adjacent Data Leakage that Western OSINT frameworks do not account for, because the concept of a "name search" carrying this level of blast radius simply does not exist in their operational context.

MIZAN adaptation: Any search operation that uses a family name as a primary query parameter in a high-connectivity context must be flagged for elevated Adjacency review. The investigator must document why a name-based search was necessary and what filters were applied to limit collateral data collection.

5.3 Cultural Privacy Norms and Gendered Data Sensitivity

Privacy expectations in Saudi Arabia and the GCC differ fundamentally from Western norms, particularly regarding gendered data. Photographs, social media profiles, and personal details of female family members carry a significantly higher Sensitivity score (S) in this context, regardless of whether the data is technically "public."

A woman's Instagram profile may be set to public, but her family and community may treat that profile as functionally private. Accessing, storing, or analyzing such data without explicit justification constitutes a cultural privacy violation that no existing Western OSINT framework accounts for.

MIZAN adaptation: In high-connectivity contexts, the Sensitivity score (S) for data involving family members — particularly female family members — is elevated by a cultural modifier. This modifier reflects the gap between "technically public" and "culturally private" data. Investigators operating in these regions must apply this modifier regardless of platform privacy settings.

5.4 The WhatsApp and Messaging Group Problem

In the GCC region, WhatsApp and Telegram serve as the primary communication infrastructure for family, business, and social coordination. A single individual may belong to 15 to 30 active group chats, each containing 20 to 200 members. These groups often include extended family chats, neighborhood groups, professional circles, school alumni networks, and tribal coordination channels.

This creates a unique OSINT risk: if an investigator gains access to a single group membership list or message thread (through a data leak, social engineering, or platform vulnerability), the blast radius is enormous. A single group can expose an entire family tree, a complete business network, or a full social circle — none of whom may have any connection to the investigation.

MIZAN adaptation: Any evidence that originates from or references group messaging platforms in high-connectivity contexts must receive maximum Adjacency scoring. The investigator must assume that group-derived data contains a high proportion of non-target personal information and apply aggressive data minimization before storing any results.

5.5 The Small-World Professional Effect

Professional circles in Saudi Arabia — particularly in cities like Riyadh, Jeddah, and Dammam — exhibit an extreme "small-world" property. Within specific sectors (technology, finance, government, energy), most professionals are separated by only one or two degrees of connection. LinkedIn networks are dense, event attendance overlaps significantly, and professional reputation travels fast through informal channels.

This means that an OSINT investigation targeting a professional individual in Saudi Arabia is far more likely to encounter data about other professionals in the same sector. The blast radius of a professional investigation is wider and more interconnected than in larger, more diffuse professional markets.

Example scenario: Investigating a fintech executive in Riyadh through LinkedIn analysis will almost certainly surface profiles and connection data for a significant portion of the Saudi fintech ecosystem — investors, regulators, co-founders of competing companies, and government officials. In a Western context, the same investigation would surface a much more diluted professional network.

5.6 Location Data and Social Platform Behavior

Snapchat Map (Snap Map), Instagram location tags, and Foursquare/Swarm check-ins are widely used in the GCC region. Mall check-ins, restaurant location tags, and travel posts create a granular movement pattern that is far more revealing in cities with a high concentration of social and commercial activity in a small geographic area.

In Riyadh, for example, a location tag at a specific mall or district can narrow an individual's identity significantly when combined with other data points. The density of commercial and social activity in GCC cities means that location data carries higher informational value per data point than in more geographically dispersed cities.

MIZAN adaptation: Location-derived data in high-density urban environments within the GCC receives an elevated Sensitivity score. Investigators must apply temporal anonymization (removing exact timestamps) and spatial generalization (reducing precision of GPS coordinates) when storing location-derived evidence.

5.7 Legal Framework: Saudi Personal Data Protection Law (PDPL)

Saudi Arabia's Personal Data Protection Law (PDPL), which came into full effect in September 2024, establishes specific requirements for the collection, processing, and storage of personal data. Key provisions relevant to OSINT practitioners include:

- **Explicit Consent:** Personal data may not be collected or processed without the data subject's explicit consent, with limited exceptions for public safety and legal compliance.
- **Purpose Limitation:** Data collected for one purpose may not be repurposed for another without additional consent.
- **Data Minimization:** Only data that is directly necessary for the stated purpose may be collected.
- **Cross-Border Transfer Restrictions:** Personal data of Saudi residents may not be transferred outside the Kingdom without specific safeguards and approvals.
- **Penalties:** Violations can result in fines of up to 5 million SAR (approximately 1.33 million USD) and potential imprisonment.

The MIZAN Protocol's PoEC documentation directly supports PDPL compliance by providing auditable records of data provenance, purpose justification, and minimization practices. Investigators operating under MIZAN can demonstrate compliance through their PoEC signatures, which serve as contemporaneous evidence that data handling followed established legal requirements.

5.8 Vision 2030 and Accelerated Digitization

Saudi Arabia's Vision 2030 initiative has dramatically accelerated the digitization of public and private services. Government platforms like Absher, Tawakkalna, and the National Address system have moved personal information online at scale. Digital payments through mada and Apple Pay have created financial data trails. E-commerce adoption has surged, creating purchase and delivery address data.

This accelerated digitization means that the volume of personal data available through OSINT methods in Saudi Arabia has grown exponentially in recent years, while the cultural and legal frameworks for protecting that data are still maturing. The gap between data availability and data protection creates an urgent need for frameworks like MIZAN that impose ethical constraints at the investigator level, rather than relying solely on platform-level protections.

5.9 Adjusted Scoring Recommendations for High-Connectivity Contexts

Based on the factors described above, the MIZAN Protocol recommends the following adjustments when operating in high-connectivity cultural contexts:

- **Adjacency (A) Multiplier:** Apply a 1.5x to 2.0x multiplier to all Adjacency scores to account for denser family and professional networks.
- **Sensitivity (S) Cultural Modifier:** Apply an additional +0.2 to +0.3 to the Sensitivity score for any data involving family members, gendered data, or culturally sensitive information.
- **Entropy (E) Threshold Reduction:** Lower the acceptable Entropy threshold by 0.1 to 0.2 to account for the increased risk of detection in smaller, more interconnected communities where unusual digital activity is more likely to be noticed and discussed.
- **Family Name Operations:** Require explicit PoEC justification for any search operation that uses a family or tribal name as the primary query parameter.
- **Group Data Handling:** Apply maximum Adjacency scoring to any data derived from messaging group memberships or message threads.

---

6. Novelty Statement

A review of existing literature confirms that while several OSINT ethics frameworks exist (notably the OSINT Privacy Impact Framework by New America Foundation, and various industry best-practice guidelines from OSINT Industries and SOSIntel), none of them provide:

1. A **mathematical formula** for pre-computing ethical risk before data collection.
2. A formal **zero-touch methodology** (MIES) integrated with ethical compliance.
3. A **chain-of-custody documentation standard** (PoEC) that combines technical provenance with ethical justification.

The MIZAN Protocol is, to the best of available knowledge, the first framework to combine quantitative ethical risk assessment with operational methodology and evidence documentation into a single, reproducible protocol for OSINT practitioners.

---

7. Conclusion: Towards Defensive OSINT

The MIZAN Protocol is not merely a set of rules. It is a **Security Architecture** for the next generation of digital investigators. By quantifying ethics through the Blast Radius Calculus, enforcing minimal-interaction methods through MIES, and documenting compliance through PoEC, we protect both the subject and the investigator from legal, ethical, and operational liability.

The ultimate goal is the transformation of OSINT from an ad-hoc practice into a disciplined engineering science — one where digital silence is the highest form of professional mastery.

BibTeX Citation

```
@techreport{mizan2026,
  title = {MIZAN: A Quantitative Framework for Non-Invasive OSINT Compliance},
  year = {2026},
  month = {March},
  url = {https://github.com/gqnxx/MIZAN-Protocol}
}
```

[ملخص تنفيذي]

يركز البروتوكول على "حساب نصف قطر التأثير (OSINT). يقدم هذا البحث "بروتوكول ميزان"، وهو إطار عمل رياضي يهدف إلى ضبط الأخلاقيات في التحقيقات الاستخباراتية مفتوحة المصدر الرقمي" لتقليل الأضرار الجانبية وضمان عدم لفت انتباه الأهداف أثناء عمليات البحث. يتميز هذا العمل بأنه الأول من نوعه في الجمع بين التقييم الرياضي للمخاطر الأخلاقية ومنهجية التحقيق الخفي وتوثيق سلسلة العهدة الرقمية في بروتوكول واحد قابل للتكرار.